Министерство науки и высшего образования Российской Федерации
Федеральное государственное автономное образовательное учреждение
высшего образования
«Московский государственный технический университет имени Н.Э. Баумана
(национальный исследовательский университет)»
(МГТУ им. Н.Э. Баумана)

ФАКУЛЬТЕТ **ИНФОРМАТИКА И СИСТЕМЫ УПРАВЛЕНИЯ**

КАФЕДРА **КОМПЬЮТЕРНЫЕ СИСТЕМЫ И СЕТИ (ИУ6)**

НАПРАВЛЕНИЕ ПОДГОТОВКИ **09.03.03 ПРИКЛАДНАЯ ИНФОРМАТИКА**

Д О М А Ш Н Е Е З А Д А Н И Е

Название: Электронная почта

Дисциплина: Защита информации

Студент	ИУ6-84Б		Д.О. Кошенков
	(Группа)	(Подпись, дата)	(И.О. Фамилия)
Преподаватель			Д.А. Миков
		(Подпись, дата)	(И.О. Фамилия)

Москва, 2026

ВВЕДЕНИЕ

Объект исследования: система электронной почты (далее - система).

Назначение системы: система предназначена для обеспечения обмена электронными сообщениями между пользователями, передачи вложений, хранения переписки, уведомлений и служебной информации. Пользователь формирует, отправляет, получает, читает, пересылает и удаляет электронные письма. Система также обеспечивает хранение почтовых ящиков, маршрутизацию сообщений, аутентификацию пользователей и администрирование почтовой инфраструктуры.

Система имеет типовую клиент-серверную архитектуру и включает следующие компоненты:

1) почтовый клиент (веб-интерфейс, мобильное приложение или десктопное приложение);

2) почтовый сервер отправки сообщений;

3) почтовый сервер приема и хранения сообщений;

4) сервер аутентификации и управления учетными записями;

5) сервер базы данных и/или почтовое хранилище;

6) антивирусный и антиспам-шлюз;

7) каналы связи для передачи сообщений между узлами системы.

1 Основные источники информации

Пользователь:

1) электронные письма, создаваемые и отправляемые через систему;

2) вложения к письмам (документы, изображения, архивы и др.);

3) учетные данные для аутентификации (логин, пароль);

4) адресная книга, контакты, черновики;

5) команды на выполнение операций (отправка, чтение, удаление, пересылка сообщений).

Почтовые серверы и внутренняя инфраструктура:

1) содержимое входящих и исходящих писем;

2) журналы доставки, маршрутизации и ошибок;

3) сведения о времени отправки и получения сообщений;

4) данные о сессиях пользователей;

5) метаданные сообщений (отправитель, получатель, тема, дата, технические заголовки).

Система аутентификации и администрирования:

1) учетные записи пользователей и администраторов;

2) политики доступа и параметры безопасности;

3) сведения о правах пользователей;

4) настройки доменов, почтовых ящиков, фильтров, маршрутов доставки.

Внешняя среда:

1) DNS-записи, обеспечивающие маршрутизацию почты;

2) временные метки и системное время;

3) обновления программного обеспечения;

4) списки блокировки спама и вредоносных источников.

Классификация информации

Вся информация в системе электронной почты делится на категории в зависимости от значимости свойств безопасности.

Конфиденциальная информация:

1) содержимое электронных писем;

2) вложения к письмам;

3) учетные данные пользователей;

4) адресные книги и списки контактов;

5) служебная переписка, содержащая коммерческую тайну, персональные данные или иную защищаемую информацию;

6) данные аутентификационных сессий.

Информация, требующая целостности:

1) содержимое сообщений при передаче и хранении;

2) журналы событий и аудита;

3) настройки почтовых ящиков и правил фильтрации;

4) учетные записи пользователей;

5) программное обеспечение почтовой системы;

6) DNS- и почтовые настройки маршрутизации.

Информация, требующая доступности:

1) почтовый веб-интерфейс и почтовые клиенты;

2) серверы отправки, приема и хранения сообщений;

3) службы аутентификации;

4) антивирусные и антиспам-компоненты;

5) сетевые каналы связи.

2 Виды угроз

Анализ угроз проводится по трем основным свойствам информации: конфиденциальности, целостности и доступности.

Угрозы конфиденциальности связаны с несанкционированным ознакомлением с информацией.

Перехват почтового трафика. Внешний нарушитель реализует атаку на каналы связи между клиентом и сервером либо между почтовыми серверами. Объект угрозы - содержимое писем, учетные данные и вложения.

Компрометация учетной записи. Нарушитель получает доступ к почтовому ящику путем подбора пароля, фишинга или использования украденных учетных данных. Объект угрозы - вся переписка пользователя, адресная книга, вложения.

Утечка сообщений через вредоносное ПО. На рабочем месте пользователя или администратора устанавливается вредоносная программа, передающая содержимое писем третьим лицам.

Несанкционированный доступ администратора или инсайдера. Внутренний нарушитель использует привилегии для просмотра переписки пользователей.

Угрозы целостности направлены на искажение или подмену информации.

Подмена содержимого письма. Нарушитель модифицирует письмо в процессе передачи или хранения, искажая его текст, вложения или адресные данные.

Фальсификация служебных заголовков. Внешний нарушитель подделывает адрес отправителя, маршрут письма или технические метки для обмана получателя.

Изменение журналов событий. Внутренний нарушитель удаляет или корректирует записи аудита, чтобы скрыть факт несанкционированного доступа или отправки сообщений.

Модификация настроек почтовой системы. Ошибочные либо злонамеренные действия администратора приводят к изменению правил маршрутизации, фильтрации или хранения почты.

Угрозы доступности нарушают нормальное функционирование системы.

DDoS-атака на почтовый сервер. Внешний нарушитель перегружает инфраструктуру большим количеством запросов, нарушая доступ пользователей к почте.

Переполнение почтовых хранилищ. Массовая отправка писем или вложений приводит к исчерпанию дискового пространства и отказу в обслуживании.

Заражение серверов вредоносным ПО. Использование программ-вымогателей или разрушительных вредоносных программ блокирует доступ к письмам и хранилищам.

Отказ оборудования или программного обеспечения. Сбои дисковой подсистемы, базы данных или почтовых служб делают невозможными прием, отправку или чтение сообщений.

3 Источники угроз

Источники угроз подразделяются на внешние и внутренние по отношению к системе.

Внешние источники:

1) злоумышленники из сети Интернет, осуществляющие подбор паролей, фишинг, DDoS и иные атаки;

2) спамеры и операторы вредоносных рассылок;

3) конкуренты, заинтересованные в получении конфиденциальной переписки;

4) лица, использующие методы социальной инженерии;

5) природные и техногенные факторы (пожары, аварии электроснабжения, сбои каналов связи).

Внутренние источники:

1) пользователи системы, нарушающие правила эксплуатации;

2) администраторы и обслуживающий персонал, имеющие расширенные привилегии;

3) инсайдеры, намеренно нарушающие режим защиты информации;

4) ошибки персонала при настройке почтовых серверов;

5) сбои аппаратных и программных средств.

4 Объекты угроз

Объектами угроз являются информационные и технические компоненты системы электронной почты.

Информационные объекты:

1) содержимое электронных писем;

2) вложения;

3) учетные данные пользователей;

4) списки контактов и адресные книги;

5) журналы событий и аудита;

6) служебные настройки почтовых ящиков и правил обработки сообщений.

Технические объекты:

1) почтовые клиенты;

2) серверы приема и отправки почты;

3) серверы хранения почтовых сообщений;

4) сервер аутентификации;

5) база данных пользователей и настроек;

6) сетевые каналы связи;

7) антивирусный и антиспам-шлюзы;

8) резервные копии почтовых данных.

5 Способы доступа

Под способами доступа понимаются методы, применяемые нарушителем для реализации угроз.

Сетевые способы:

1) перехват трафика при передаче писем;

2) DDoS-атаки на почтовые серверы;

3) сканирование портов и поиск уязвимых сетевых служб;

4) эксплуатация ошибок настройки протоколов почтового обмена.

Программные способы:

1) подбор паролей и автоматизированные атаки на аутентификацию;

2) использование вредоносных вложений и ссылок в письмах;

3) внедрение вредоносного ПО через фишинговые сообщения;

4) эксплуатация уязвимостей веб-интерфейса почты;

5) использование уязвимостей в сторонних библиотеках и компонентах сервера.

Организационные и физические способы:

1) использование легитимных учетных записей сотрудников;

2) социальная инженерия для получения доступа к ящику;

3) несанкционированный физический доступ к серверному оборудованию;

4) хищение резервных копий или носителей информации;

5) нарушение регламентов администрирования.

6 Направление защиты

Для противодействия выявленным угрозам защита должна строиться по следующим направлениям:

1) защита каналов связи между клиентами и серверами, а также между почтовыми серверами;

2) защита учетных записей и механизмов аутентификации;

3) защита почтового содержимого и вложений при хранении;

4) защита серверной инфраструктуры от сетевых и программных атак;

5) защита журналов и служебной информации от подмены и уничтожения;

6) обеспечение резервирования и восстановления данных;

7) организационные меры по разграничению прав доступа и контролю действий персонала.

7 Политика безопасности

Политика безопасности распространяется на всех пользователей электронной почты, а также на администраторов и технический персонал, обслуживающий систему.

Цели политики безопасности: обеспечение конфиденциальности переписки и вложений; обеспечение целостности почтовых сообщений, журналов и настроек; обеспечение доступности сервиса электронной почты для пользователей.

Правила управления доступом

1) каждому пользователю предоставляется уникальная учетная запись;

2) идентификация и аутентификация обязательны для всех пользователей и администраторов;

3) доступ к почтовому ящику разрешается только его владельцу и уполномоченным администраторам в пределах их служебных обязанностей;

4) применяется принцип минимальных привилегий;

5) для административных учетных записей обязательно использование многофакторной аутентификации;

6) запрещается передача паролей третьим лицам и использование общих учетных записей.

Правила обеспечения конфиденциальности

1) передача данных должна осуществляться по защищенным каналам связи;

2) доступ к письмам и вложениям должен разграничиваться по ролям;

3) учетные данные хранятся в защищенном виде;

4) резервные копии, содержащие почтовые данные, должны храниться в защищенном и контролируемом хранилище;

5) пересылка конфиденциальной информации без разрешения запрещается.

Правила обеспечения целостности

1) запрещается несанкционированное изменение содержимого почтовых сообщений, журналов и системных настроек;

2) все изменения конфигурации почтовой системы подлежат регистрации;

3) программное обеспечение почтовой системы должно обновляться контролируемым образом;

4) журналы аудита должны быть защищены от удаления и подмены;

5) критические изменения в настройках должны выполняться только уполномоченными лицами.

Правила обеспечения доступности

1) почтовая система должна поддерживаться в работоспособном состоянии посредством мониторинга и профилактического обслуживания;

2) должны выполняться регулярное резервное копирование и проверка восстановления;

3) критические компоненты системы должны иметь средства отказоустойчивости;

4) должен существовать порядок реагирования на инциденты и восстановления после сбоев.

Правила регистрации и учета

1) регистрируются события входа и выхода пользователей;

2) регистрируются факты изменения паролей, настроек безопасности и административных параметров;

3) регистрируются попытки неуспешной аутентификации;

4) регистрируются действия администраторов;

5) сроки хранения журналов определяются внутренним регламентом организации.

Ответственность

Нарушение требований политики безопасности влечет дисциплинарную, административную или иную ответственность в соответствии с внутренними документами организации и действующим законодательством.

8 Средства и методы защиты информационных процессов

Описание информационных процессов

Аутентификация пользователя. Пользователь вводит учетные данные для доступа к почтовому ящику. Необходимо обеспечить защиту паролей, контроль попыток входа и, при необходимости, многофакторную аутентификацию.

Отправка письма. Пользователь формирует сообщение и передает его почтовому серверу. Необходимо защищать содержимое письма, вложения и служебные заголовки от перехвата и модификации.

Прием и хранение письма. Письмо поступает на сервер, обрабатывается и сохраняется в почтовом хранилище. Требуется обеспечить сохранность данных, контроль доступа и резервное копирование.

Чтение и обработка письма. Пользователь получает доступ к сообщениям через клиентское приложение. Требуется защита сессии, защита от фишинговых сообщений, вредоносных вложений и поддельных отправителей.

Администрирование системы. Администратор настраивает серверы, учетные записи и правила безопасности. Требуется использование защищенных каналов, разграничение прав и аудит действий.

Программно-технические средства защиты

1) использование защищенных протоколов связи для доступа к почте и межсерверного обмена;

2) применение многофакторной аутентификации для администраторов и, при необходимости, пользователей;

3) использование антиспам- и антивирусных шлюзов для фильтрации входящей и исходящей корреспонденции;

4) контроль сложности паролей и ограничение числа неуспешных попыток входа;

5) применение межсетевых экранов и систем обнаружения вторжений;

6) резервное копирование почтовых ящиков, баз данных и конфигураций;

7) журналирование действий пользователей и администраторов;

8) регулярное обновление программного обеспечения почтовой системы;

9) контроль целостности конфигураций и журналов.

Организационные методы защиты

1) разработка регламента использования корпоративной электронной почты;

2) обучение пользователей распознаванию фишинговых сообщений и правилам безопасной работы с вложениями;

3) распределение ролей и обязанностей администраторов;

4) проведение регулярных проверок настроек безопасности;

5) периодическая смена паролей для привилегированных учетных записей;

6) организация контроля резервного копирования и восстановления;

7) ограничение доступа персонала к серверному оборудованию и резервным носителям.

ЗАКЛЮЧЕНИЕ

В ходе работы проанализирована система электронной почты как объект защиты информации. Выявлены основные риски нарушения конфиденциальности, целостности и доступности почтовой информации. К ключевым угрозам относятся компрометация учетных записей, перехват и подмена сообщений, вредоносные вложения, внутренние нарушения, DDoS-атаки и сбои инфраструктуры.

Разработанная политика безопасности определяет правила доступа, регистрации событий, обеспечения конфиденциальности, целостности и доступности почтового сервиса. Для защиты информационных процессов предложен комплекс мер, включающий программно-технические и организационные средства защиты.

Предложенные меры позволяют снизить вероятность реализации угроз и обеспечить устойчивое и безопасное функционирование системы электронной почты.